

# 보세전시장 챗봇

## 대규모 정밀 수정 계획안

프로젝트: bonded-exhibition-chatbot-data

버전: v14.0.0 → v15.0.0

작성일: 2026-05-10

대상 파일: 40개 소스 + 12개 설정/배포 파일

총 발견 이슈: 24건 (Critical 4 / High 6 / Medium 8 / Low 6)

수정 Phase: 7단계 순차 실행

## 1. 전체 현황 분석

보세전시장 챗봇 프로젝트(v14.0.0)의 40개 소스 파일, 90+개 테스트 파일, 12개 설정/배포 파일을 전수 분석한 결과, 총 24건의 수정 필요 이슈를 발견했습니다. 본 문서는 전체 코드베이스를 처음부터 다시 쓴다는 관점에서 7개 Phase로 구성된 정밀 수정 계획을 제시합니다.

### 1.1 이슈 심각도 분포

| 심각도      | 건수 | 요약                                                      |
|----------|----|---------------------------------------------------------|
| CRITICAL | 4건 | 인증/보안 — 하드코딩 비밀번호, SHA256 해싱, JWT 시크릿, 인증 우회            |
| HIGH     | 6건 | 런타임 버그 — SQL 구문오류, 메모리 누수 3건, 세션 기본값 반전, 차트 빈 반환        |
| MEDIUM   | 8건 | 아키텍처/설정 — SSL 미설정, CORS, 캐시 락, CI 테스트 제외, CD 배포 취약      |
| LOW      | 6건 | 코드 품질 — deprecated API, 타입힌트 미비, 테스트 누락 9개, $O(n^2)$ 성능 |

### 1.2 크로스커팅 아키텍처 문제점

- SQLite vs PostgreSQL 불일치: db/schema.sql은 PostgreSQL 23개 테이블을 정의하지만, 실제 모든 Python 코드는 SQLite 사용
- TF-IDF 로직 3중 중복: bm25\_ranker.py, question\_cluster.py, faq\_recommender.py가 각각 독립적으로 구현
- DB 연결 풀링 부재: 15개 이상 모듈이 각각 독립적으로 SQLite 연결 생성
- analytics.py와 conversation\_analytics.py가 logger\_db.\_get\_conn() 비공개 API 직접 접근
- BASE\_DIR 경로 계산이 거의 모든 모듈에서 독립적으로 반복

## 2. Phase별 상세 수정 계획

### Phase 1 보안 긴급 수정 3개 파일 | CRITICAL

#### 2.1.1 auth.py — 비밀번호 해싱 교체

현재 상태: SHA-256 + 단일 라운드 해싱 (line 32-39). 정부 시스템에 부적합.

- hashlib.sha256 → bcrypt (cost factor 12) 또는 argon2id로 교체
- hash\_password() 함수 완전 재작성
- verify\_password() 함수 bcrypt.checkpw() 기반으로 변경
- 기존 SHA256 해시 마이그레이션 함수 migrate\_legacy\_hash() 추가

```
# Before (line 38)
hash_val = hashlib.sha256((salt + password).encode()).hexdigest()

# After
import bcrypt
hash_val = bcrypt.hashpw(password.encode(), bcrypt.gensalt(rounds=12))
```

#### 2.1.2 auth.py — 하드코딩 자격증명 제거

현재 상태: admin/admin123 기본 계정 (line 65-68), JWT 시크릿 하드코딩 (line 84).

- \_DEFAULT\_ADMIN\_USERS 삭제 → 환경변수 ADMIN\_USERS 필수화
- JWT\_SECRET\_KEY 환경변수 미설정 시 서버 시작 거부 (raise RuntimeError)
- ADMIN\_AUTH\_DISABLED 환경변수 완전 제거 (line 188-196)
- TESTING 모드에서도 인증 우회 불가 → 테스트용 별도 fixture 제공

#### 2.1.3 security\_config.json — CORS 수정

현재 상태: allowed\_origins에 플레이스홀더 yourdomain.com 존재.

- allowed\_origins → 환경변수 CORS\_ORIGINS에서 로드
- 기본값 빈 배열 [] → 설정 누락 시 모든 외부 요청 차단

## Phase 2 런타임 버그 수정 5개 파일 | HIGH

### 2.2.1 satisfaction\_tracker.py:86 — SQL 구문 오류

UPDATE ... ORDER BY ... LIMIT 1 구문은 SQLite에서 지원되지 않아 런타임 오류 발생.

- 서브쿼리 패턴으로 변경:

```
UPDATE satisfaction SET re_asked = 1
WHERE rowid = (SELECT rowid FROM satisfaction
WHERE session_id = ? AND query = ?
ORDER BY timestamp DESC LIMIT 1)
```

### 2.2.2 quality\_scorer.py — 메모리 누수

\_scored\_history 리스트가 무한정 성장. 장기 운영 시 OOM 위험.

- list → collections.deque(maxlen=10000)로 교체
- 주기적 정리 메서드 cleanup\_old\_scores(days=30) 추가

### 2.2.3 realtime\_monitor.py — 세션 누수

\_active\_sessions set에 세션이 추가만 되고 제거되지 않음.

- end\_session(session\_id) 메서드 추가
- TTL 기반 자동 만료: {session\_id: timestamp} dict, 30분 미활동 시 제거

### 2.2.4 session.py:143 — 기본값 반전

\_is\_positive\_response()가 인식 불가 시 True 반환. 정부 시스템에서 모호한 응답을 동의로 해석 불가.

- 기본값 True → None 반환으로 변경
- 호출측에서 None일 경우 재확인 요청 로직 추가

### 2.2.5 chart\_data.py — 빈 히스토그램

response\_time\_histogram()이 존재하지 않는 response\_time 컬럼 조회.

- logger\_db 테이블에 response\_time\_ms 컬럼 추가 (migration 파일 생성)
- ChatLogger.log()에 응답 시간 기록 로직 추가

## Phase 3 아키텍처 개선 8개 파일 | MEDIUM

### 2.3.1 DB 연결 풀링 통합

15개+ 모듈이 각각 SQLite 연결 생성. 경로도 모듈마다 독립 계산.

- src/db\_pool.py 신규 모듈 생성: DatabasePool 클래스
- 중앙 경로 관리: BASE\_DIR, DB 경로를 한 곳에서 관리
- WAL 모드, journal\_mode, busy\_timeout 통일 설정
- 영향 범위: feedback, law\_updater, flow\_analyzer, context\_memory, faq\_diff, auto\_faq\_pipeline, tenant\_manager, alert\_center, audit\_logger, logger\_db, chart\_data, satisfaction\_tracker, conversation\_export, db\_migration, analytics (15개)

### 2.3.2 세션 저장소 교체

- SessionManager 내부 저장소를 SQLite(WAL)로 교체
- 세션 TTL 자동 정리 스케줄러 추가

### 2.3.3 TF-IDF 중복 제거

- src/text\_similarity.py 신규 모듈로 통합: TfidfVectorizer, CosineSimilarity
- bm25\_ranker, question\_cluster, faq\_recommender가 공통 모듈 import

### 2.3.4 logger\_db 비공개 API 접근 제거

- ChatLogger에 공개 메서드 get\_connection() 추가
- analytics, conversation\_analytics가 공개 API 사용하도록 변경

### 2.3.5 max\_query\_length 불일치 해소

- security\_config.json의 값을 Single Source of Truth로 설정
- domain\_config에서 security\_config 값을 참조하도록 변경

## Phase 4 스레드 안전성 강화 5개 파일 | MEDIUM

### 2.4.1 escalation.py — 글로벌 캐시 락

- \_escalation\_rules\_cache, \_contacts\_cache에 threading.Lock 추가
- 캐시 TTL 방식 갱신 로직 추가 (기본 300초)
- 함수를 CachedResourceLoader 클래스로 리팩토링

### 2.4.2 webhook\_manager.py:336 — dir() 오용 수정

- 'attempt' in dir() → attempt 변수 직접 참조로 변경
- 데몬 스레드 배달 로직 검토 및 Lock 범위 확대

### 2.4.3 auth.py — \_users dict 락

- 모듈 레벨 \_users dict에 threading.RLock 추가

### 2.4.4 db\_migration.py — 마이그레이션 락

- MigrationManager.migrate()에 threading.Lock 추가

### 2.4.5 data\_validator.py — 파일 I/O 캐싱

- 매 호출마다 JSON 파일 로드 → 캐시 + TTL 패턴으로 변경

## Phase 5 코드 품질 &amp; 타입 안전성 40개 파일 | LOW

## 2.5.1 타입 힌트 보강 (40개 파일)

| 파일                               | 현재        | 목표                               |
|----------------------------------|-----------|----------------------------------|
| analytics.py (253L)              | Minimal   | 전체 메서드 시그니처 타입 추가                |
| conversation_analytics.py (606L) | Minimal   | 전체 메서드 + PatternDetector 타입 추가   |
| escalation.py (60L)              | None      | 함수 시그니처 + 리턴 타입                  |
| tenant_manager.py (283L)         | None      | 전체 메서드 타입 추가                     |
| plugin_system.py (80L)           | Incorrect | callable → Callable[..., Any] 수정 |
| 외 14개 파일                         | Partial   | 부분 보완                            |

- 전체 파일에 리턴 타입, 매개변수 타입 추가
- typing 모듈 스타일(Dict, List) → 빌트인 제네릭(dict, list) 통일
- mypy --strict 모드 설정 및 CI 통합

## 2.5.2 deprecated API 교체

- api\_gateway.py:18 — datetime.utcnow() → datetime.now(timezone.utc)

## 2.5.3 예외 핸들링 표준화

- utils.py — load\_json, load\_text에 try/except + 커스텀 예외 클래스 추가
- 전체 모듈 bare except → 구체적 예외 타입으로 변경

## 2.5.4 템플릿 엔진 XSS 방어

- template\_engine.py \_substitute\_variables()에 html.escape() 추가

2.5.5 related\_faq.py  $O(n^2)$  성능 개선

- 유사도 행렬 지연 계산 (Lazy computation) 패턴으로 변경
- FAQ 1000개 초과 시 ANN(Approximate Nearest Neighbor) 도입 검토

## Phase 6 테스트 &amp; CI/CD 강화 12개 파일 | MEDIUM

## 2.6.1 누락 테스트 9개 파일 추가

| 대상 모듈                       | 테스트 범위                                         |
|-----------------------------|------------------------------------------------|
| src/Utils.py                | load_json 실패, load_text 실패, normalize_query 검증 |
| src/clarification.py        | ClarificationEngine 모호한 질문 처리, 카테고리 분류         |
| src/related_faq.py          | RelatedFAQFinder 유사도 계산, 빈 FAQ 입력 처리           |
| src/bm25_ranker.py          | BM25Ranker 랭킹 정확성, 한국어 토큰 처리                   |
| src/satisfaction_tracker.py | SQL 버그 수정 후 회귀테스트, 통계 계산                       |
| src/plugin_system.py        | PluginManager 등록/실행/제거 검증                      |
| src/realtime_monitor.py     | record_event, 세션 만료, 동시성 테스트                   |
| src/faq_quality_checker.py  | FAQQualityChecker 품질 점수 경계값 검증                 |
| src/conversation_export.py  | ConversationExporter CSV/HTML 출력 검증            |

## 2.6.2 CI 파이프라인 강화

- ci.yml: --ignore로 제외된 e2e/통합/성능 테스트 복원
- main 브랜치 push 시 전체, PR 시 단위 테스트만 실행하는 2단계 전략
- mypy --strict 체크 추가, 커버리지 90% 미달 시 CI 실패

## 2.6.3 conftest.py 안전한 fixture 패턴

- 프로덕션 data/faq.json 직접 수정 → tmp\_path fixture 사용

## 2.6.4 CD 파이프라인 강화

- cd.yml: git pull 방식 → Docker 이미지 기반 배포로 전환
- 실패 시 deploy/rollback.sh 자동 실행 통합



## Phase 7 배포 & 설정 정비 6개 파일 | MEDIUM

### 2.7.1 nginx SSL 활성화

- deploy/nginx.conf SSL 블록 주석 해제 및 활성화
- HTTP → HTTPS 301 리다이렉트, Let's Encrypt, HSTS, OCSP Stapling

### 2.7.2 PostgreSQL 스키마 정합

- 선택지 A: schema.sql을 SQLite 호환으로 재작성 (현실적 방안)
- 선택지 B: SQLAlchemy ORM 도입하여 DB 추상화 (장기 방안)

### 2.7.3 gunicorn 설정 최적화

- sync workers → gthread workers (threads=4), graceful\_timeout 30초

### 2.7.4 환경변수 템플릿

- .env.example 생성: JWT\_SECRET\_KEY, ADMIN\_USERS, CORS\_ORIGINS, DB\_PATH
- 필수 환경변수 누락 시 서버 시작 거부 로직

### 2.7.5 openapi.yaml / law\_updater.py

- server URL 플레이스홀더 제거, compute\_data\_hash() MD5 → SHA-256

### 3. 실행 우선순위 및 의존성

각 Phase는 순차적으로 실행되며, 이전 Phase 완료 후 다음으로 진행합니다.

| Phase | 제목          | 파일수 | 심각도      | 의존성      |
|-------|-------------|-----|----------|----------|
| P1    | 보안 긴급 수정    | 3   | CRITICAL | 없음 (최우선) |
| P2    | 런타임 버그 수정   | 5   | HIGH     | P1 완료 후  |
| P3    | 아키텍처 개선     | 8   | MEDIUM   | P2 완료 후  |
| P4    | 스레드 안전성     | 5   | MEDIUM   | P3 완료 후  |
| P5    | 코드 품질       | 40  | LOW      | P4 완료 후  |
| P6    | 테스트 & CI/CD | 12  | MEDIUM   | P5 완료 후  |
| P7    | 배포 & 설정     | 6   | MEDIUM   | P6 완료 후  |

## 4. 파일별 수정 매트릭스

| 파일                          | Phase | 수정 내용                                 |
|-----------------------------|-------|---------------------------------------|
| src/auth.py                 | P1,4  | bcrypt 교체, JWT 외부화, 기본계정 제거, _users 락 |
| config/security_config.json | P1    | CORS 플레이스홀더 제거                        |
| src/satisfaction_tracker.py | P2    | SQL UPDATE 서버쿼리 패턴                    |
| src/quality_scorer.py       | P2    | _scored_history deque 교체              |
| src/realtime_monitor.py     | P2    | _active_sessions TTL dict             |
| src/session.py              | P2,3  | 기본값 None, SQLite 저장소                  |
| src/chart_data.py           | P2    | response_time_ms 컬럼 추가                |
| src/logger_db.py            | P3    | get_connection() 공개 API               |
| src/analytics.py            | P3,5  | 공개 API 전환, 타입힌트                       |
| src/escalation.py           | P4,5  | 캐시 락, TTL, 타입힌트                       |
| src/webhook_manager.py      | P4    | dir() 수정, Lock 확대                     |
| src/db_migration.py         | P4    | threading.Lock 추가                     |
| src/data_validator.py       | P4    | JSON 캐싱 + TTL                         |
| src/utils.py                | P5    | 에러 핸들링, 타입힌트                          |
| src/api_gateway.py          | P5    | utcnow() 교체, max cap                  |
| src/template_engine.py      | P5    | XSS 방어 escape                         |
| src/related_faq.py          | P5    | Lazy computation                      |
| src/plugin_system.py        | P5    | Callable 타입 수정                        |
| tests/conftest.py           | P6    | tmp_path fixture                      |
| .github/workflows/ci.yml    | P6    | e2e 복원, mypy, 커버리지                    |
| .github/workflows/cd.yml    | P6    | Docker 배포, 롤백                         |
| deploy/nginx.conf           | P7    | SSL, HTTPS, HSTS                      |
| deploy/gunicorn_config.py   | P7    | gthread, timeout                      |
| db/schema.sql               | P7    | SQLite 호환 또는 미사용 명시                   |
| src/law_updater.py          | P7    | MD5 → SHA-256                         |
| api/openapi.yaml            | P7    | URL 플레이스홀더 제거                         |

## 5. 검증 계획

### 5.1 Phase별 검증 항목

- P1: bcrypt 해싱 테스트, JWT 시크릿 미설정 시 서버 거부 확인, 기본계정 제거 확인
- P2: satisfaction SQL 실행 테스트, 메모리 누수 방지 단위테스트, chart\_data 반환값 검증
- P3: 다중 워커 환경에서 세션 공유 테스트, DB풀 연결 재사용 확인
- P4: 동시성 테스트 (concurrent.futures), 데드락 부재 검증
- P5: mypy --strict 전체 패스, ruff 린트 통과
- P6: pytest --cov 커버리지 90%+, CI 파이프라인 전체 통과
- P7: SSL Labs A+ 등급, Docker 이미지 빌드/배포 전체 테스트

### 5.2 최종 통합 검증

- 전체 테스트 스위트 실행 (90개+ 테스트 파일)
- Docker 컨테이너 빌드 및 health check 통과
- 시뮬레이터(simulator.py) 기반 E2E 테스트
- 보안 점검: 하드코딩 자격증명 잔류 grep 검색
- CHANGELOG v15.0.0 작성 및 릴리즈 태그